Foundstone®

# Collecting and Hunting for Indications of Compromise with Gusto and Style!

SANS Threat Hunting & IR Summit – New Orleans, April 12, 2016

Ismael Valenzuela, GSE #132

intel Security

# (Coder + Pentester + Forensics + IR) in a SOC=?

# { about me };

Twitter: @aboutsecurity

- +15 years of experience in InfoSec
- Leading the Incident Response and Forensics team at Intel Security
- SANS Instructor
- GSE #132 + 10 other GIAC certificates
- (lazy) **coder** at heart and collector of infosec roles: **pentester**, architect, **forensics analyst**, **incident responder** and threat researcher.
- http://blog.ismaelvalenzuela.com

# { it all started a snowy winter morning };

# { the challenge }

## What was I trying to solve?

- Working as threat researcher for a large healthcare agency
- +50,000 endpoints centrally managed by McAfee ePO
- 700 events/second (17 million events/day)
- Little or no forensics in place. Triage, evidence collection, and analysis was manual and reactive
- Results of the triage process were difficult to validate and process
- Initial vector of compromise was difficult to determine
- Attacks were difficult to classify based on impact to the business
- Containment was the same on all cases (AV scan and reimage)
- No lessons learned



Intel Security Public - @aboutsecurity

# { typical day in the life of a SOC analyst };

## And why do you need more context

- Traffic blocked to a suspicious IP
  - What process is generating this traffic on the endpoint? And why?
  - Is there any other malicious activity on this host that is not being detected?
  - How do I respond to this? What should I do next?

| | | | | | | | | |
|---|---|---|---|---|---|---|---|---|
| 7 Oct 2015 11:07:35 EDT | Outgoing Traffic to CIF Malware Domain or IP | 172.17. | | n-p05.corp | | | /Failure | 86.121.110.81 |
| 7 Oct 2015 11:02:34 EDT | Outgoing Traffic to CIF Malware Domain or IP | 172.17. | | n-p05.corp | | | /Failure | 86.121.110.81 |
| 7 Oct 2015 10:57:33 EDT | Outgoing Traffic to CIF Malware Domain or IP | 172.17. | | n-p05.corp | | | /Failure | 86.121.110.81 |
| 7 Oct 2015 10:52:32 EDT | Outgoing Traffic to CIF Malware Domain or IP | 172.17. | | n-p05.corp | | | /Failure | 86.121.110.81 |

Threat feeds loaded into SIEM
(collective intelligence framework)

Source IP/host name

Suspicious domain

# { prototyping a solution: quick & dirty };

## Requirements

1. Collect host artifacts required for triage (event analysis) from all endpoints
2. Without deploying additional agents to the endpoint
3. Cross-platform
4. Must support automated, remote response
5. With minimal footprint, adhering to forensically sound procedures
6. Triage using both native and third party tools
7. Support proactive hunting for any given IoCs
8. Extensible to integrate with well known IR and forensics open source frameworks

# { automation == python };

## And why you should love Flying Circus too

1. Tons of libraries created related to security and computer forensics
2. Ideal to create quick prototypes of applications or algorithms
3. Supports the design of RESTful interfaces (client-server services)
4. Python lets me focus on concepts rather than code
5. With Pyinstaller I can freeze (package) Python programs into small stand-alone executables
6. Also… it was named after the great Monty Python!

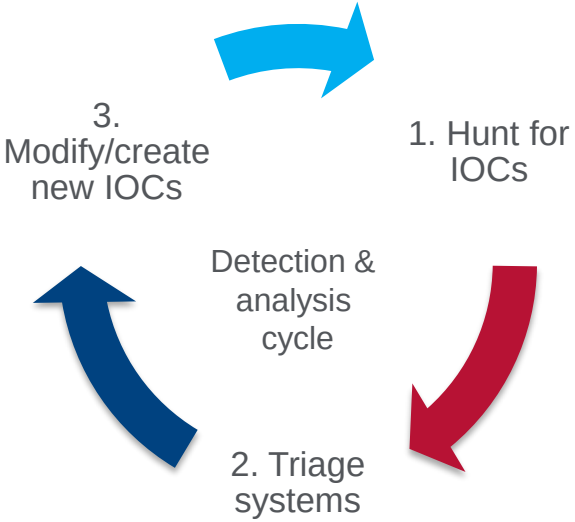
# { what do we need to automate? };

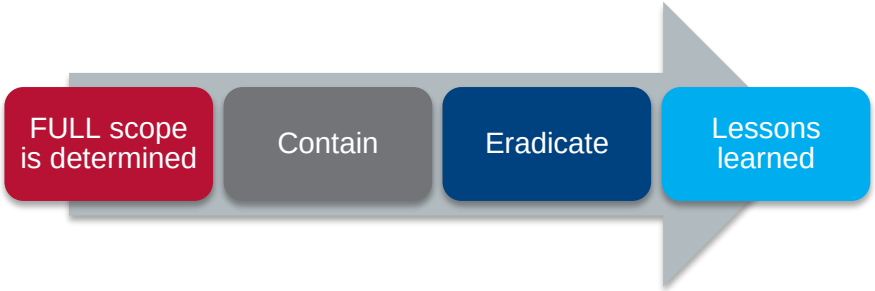
## Automated smart “triage”

- Malware doesn’t exist in a vacuum:
  - They need to run
  - They need to communicate
  - They  need to be persistent
- How do we find “evidence”?
- Traditional forensics techniques are too time consuming
- Triaging can be used to identify relevant evidence quickly and guide the IR process
- Live forensic analysis
  - Volatile data
    - Processes
    - Network connections, etc.
  - Non volatile data
    - Program execution (prefetch)
    - Autorun locations
    - Master File Table (MFT), etc.
- Dump and examine memory
- Scan with Indicators of Compromise (IOCs)

# { hunting & smart incident response };

## And why you shouldn't hunt on a Friday



# { hunting with yara };

## Simply a better GREP!

- “The pattern matching Swiss knife for malware researchers (and everyone else!)”
  - http://plusvic.github.io/yara
- Pattern matching:
  - Strings, regular expressions and binary patterns (hex strings)
- Classification:
  - On input: combination of strings & logic, stored in a YARA rule
  - On output: tags, metadata
- Can be integrated in your Python projects (bindings)
- Great repository: http://yararules.com/

**@YaraRules**

# { when you are told that you need to deploy an additional agent };

# { so how do we do all this? – **rastrea2r** };

Triage and Hunting for IOCs with ‘gusto’ and style ☺

- **Rastrea2r** (pronounced *rastreador*):
  - https://github.com/aboutsecurity/rastrea2r (opensource!)
  - Command line tool (coz command line is SEXY!)
  - Python / Multiplatform (win32/64, linux and osx)
  - Uses a REST API to report **YARA** scans
  - Wrapper to sysinternal, system command and 3rd party tools
  - Easy to integrate with McAfee ePO (but also distributable via SSCM, etc.)
  - Packaged binaries available on github

# { current functionality in **rastrea2r** v0.7 };

Triage and Hunting for IOCs with ‘gusto’ and style ☺

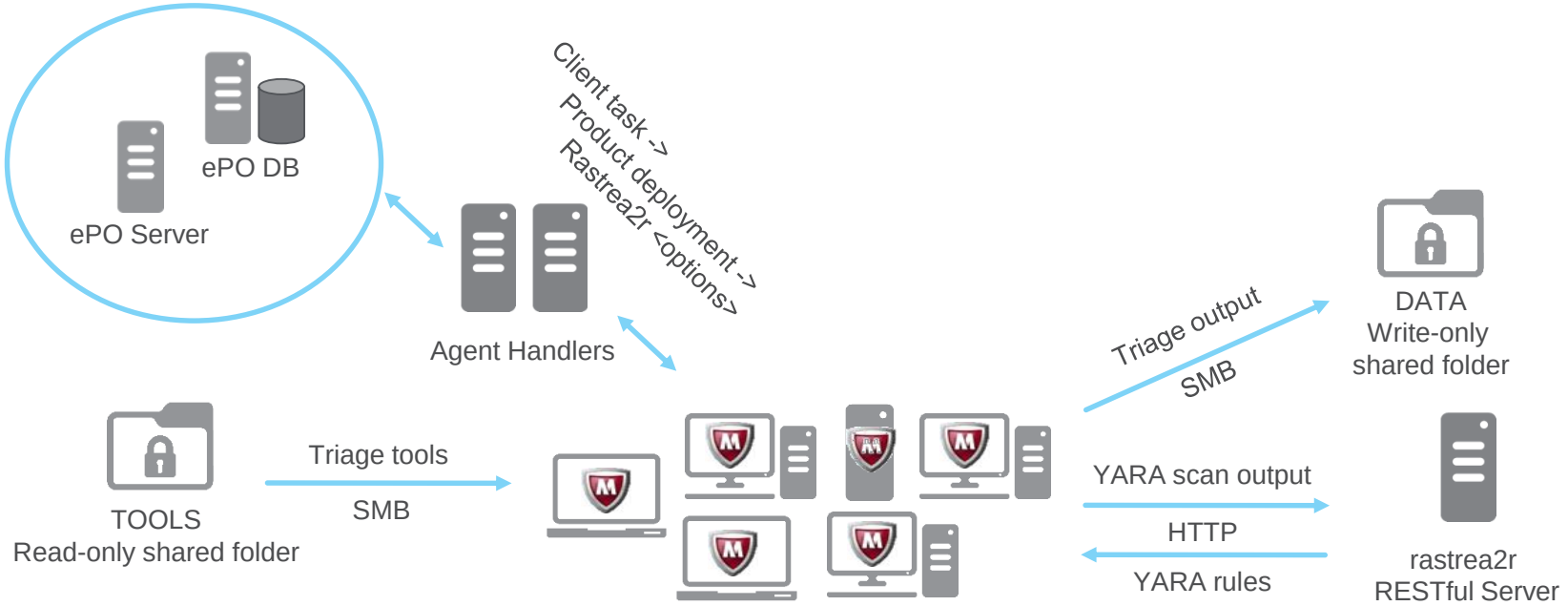
- **yara-disk**: Yara scan for file/directory objects on disk
- **yara-mem**: Yara scan for running processes in memory
- **memdump**: Acquires a memory dump from the endpoint ** Win only
- **triage**: Collects triage information from the endpoint ** Win only

Obtaining HELP:

**rastrea2r_win32_v0.7.exe –h**

# { triage + hunting on steroids = rastrea2r };

## Forensically sound architecture and communication flows



# { tr

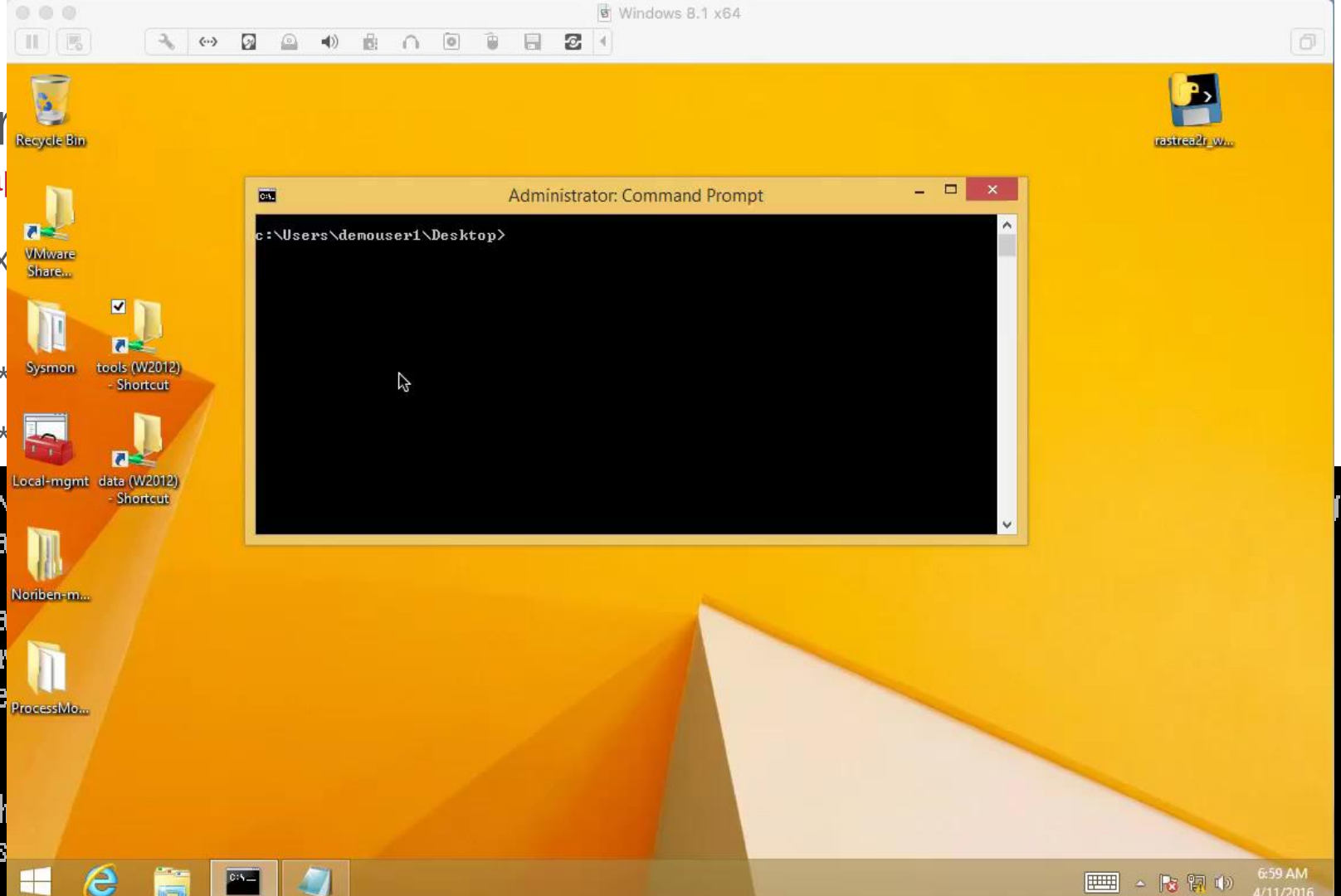
Wra

- Ex
  - 

***

***

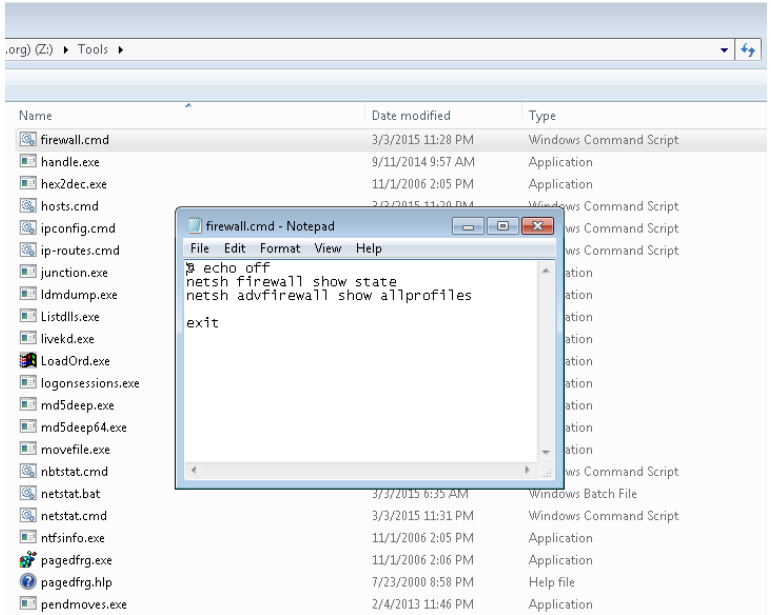
```
C:\Users\
usage: ra

positiona
  BIN_ser
  DATA_se

optional
  -h, --h
  -s, --s
```



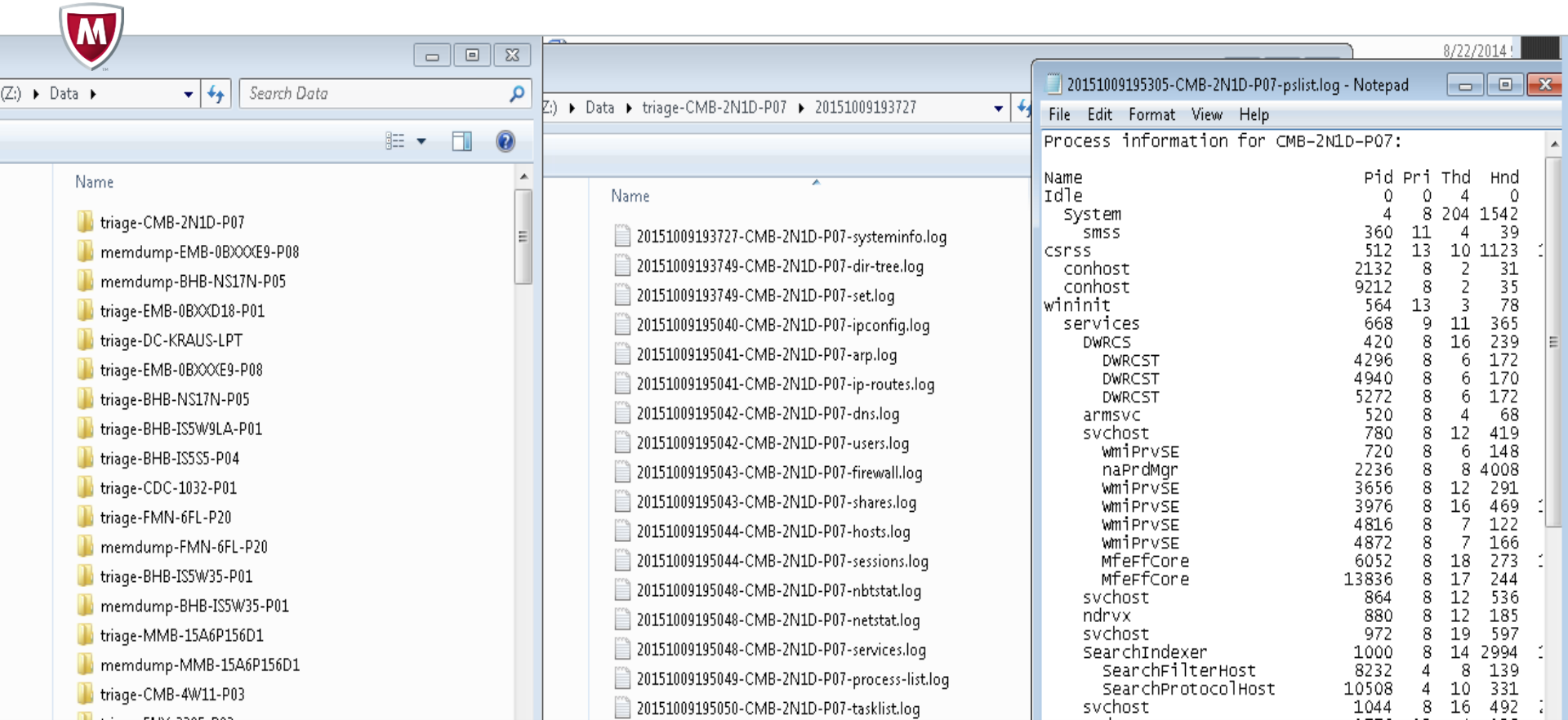
# { 3rd party tools & native win commands };

## Copy the toolset to the read-only ‘tools’ share

```
""" Add your list of Sysinternal / third-party / BATCH files here """

tool=(
     'systeminfo.cmd', # Gathers systeminfo
     'set.cmd', # Gathers Set variables
     'dir-tree.cmd', # Enumerates C:\ directory tree
     'ipconfig.cmd', # Gathers IP information
     'ip-routes.cmd', # Gathers IP routing information
     'arp.cmd', # Gathers ARP table information
     'dns.cmd', # Gathers DNS Cache information
     'users.cmd', # Gathers User/local Admin accounts
     'shares.cmd', # Gathers local shares information
     'firewall.cmd', # Gathers local firewall information
     'hosts.cmd', # Captures Host file information
     'sessions.cmd', # Gathers Active Session information
     'nbtstat.cmd', # Gathers NetBios Sessions information
     'netstat.cmd', # Gathers Netstat with process IDs
     'services.cmd', # Gathers services information
```



# { 3rd party tools & native win commands };



# { memory dumps with rastrea2r };

## Only a click away from your web console

- Example:
  - rastrea2r_win32_v0.7.exe memdump *tools.myserver.com data.myserver.com*

*** tools.myserver.com -> has a read only shared-folder called **TOOLS**

*** data.myserver.com -> has a write only shared-folder called **DATA**

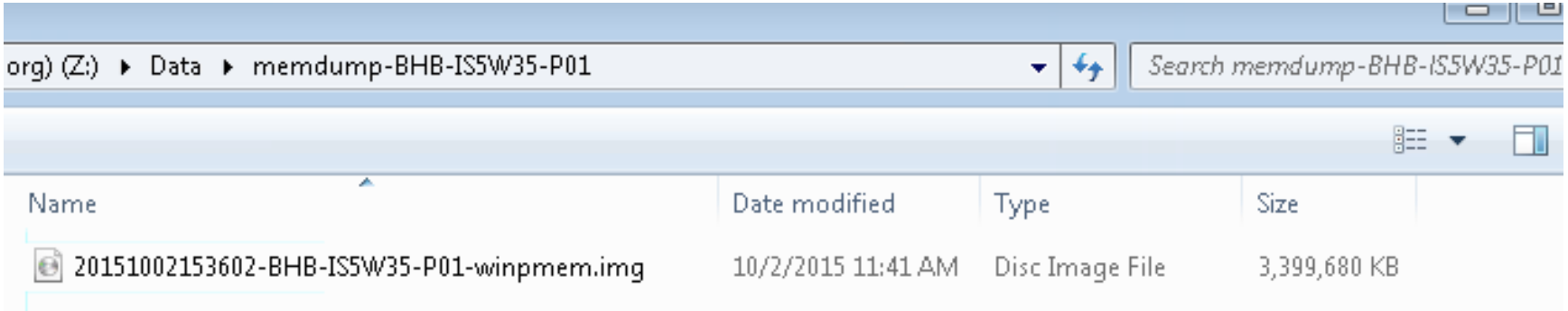
```
C:\Users\user\Desktop\rastrea2r client\rastrea2r_win32_v0.6>rastrea2r_win32_v0.6.exe memdump -h
usage: rastrea2r_win32_v0.6.exe memdump [-h] [-s] BIN_server DATA_server

positional arguments:
  BIN_server    Binary tool server (SMB share)
  DATA_server   Data output server (SMB share)

optional arguments:
  -h, --help    show this help message and exit
  -s, --silent  Suppresses standard output
```

# { memory dumps with rastrea2r };

## Memory dumps of any managed host piped over SMB using *winpmem*

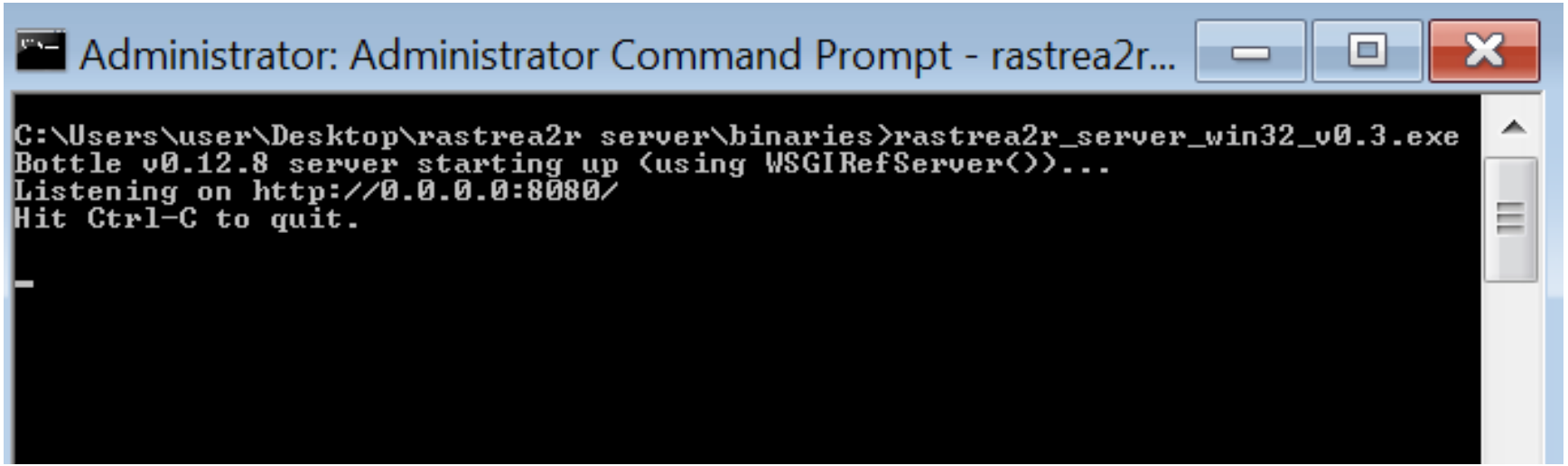
Full memory dump on RAW format:

- Ready to be parsed with memory analysis tools like volatility



# { starting the rastrea2r server };

Listening on all interfaces on port 8080



# { hunting with rastrea2r };

## IOC hunting in memory and disk a click away from your web console

*** Client / server architecture using a RESTful API

*** YARA rules must be stored on the same directory as the server

```
C:\Users\user\Desktop\rastrea2r client\rastrea2r_win32_v0.6>rastrea2r_win32_v0.6.exe yara-mem -h
usage: rastrea2r_win32_v0.6.exe yara-mem [-h] [-s] server rule

positional arguments:
  server        rastrea2r REST server
  rule          Yara rule on REST server

optional arguments:
  -h, --help    show this help message and exit
  -s, --silent  Suppresses standard output

C:\Users\user\Desktop\rastrea2r client\rastrea2r_win32_v0.6>rastrea2r_win32_v0.6.exe yara-disk -h
usage: rastrea2r_win32_v0.6.exe yara-disk [-h] [-s] path server rule

positional arguments:
  path          File or directory path to scan
  server        rastrea2r REST server
  rule          Yara rule on REST server

optional arguments:
  -h, --help    show this help message and exit
  -s, --silent  Suppresses standard output
```

# { hunting for iocs in memory with yara };

Example:

- rastrea2r_win32_v0.7.exe yara-mem *localhost ransomware.yar*

```
Scanning running processes in memory

{'cmdline': [], 'exe': None, 'pid': 0, 'name': 'System Idle Process'}
Failed scanning process ID: 0
{'cmdline': [], 'exe': None, 'pid': 4, 'name': 'System'}
Failed scanning process ID: 4
{'cmdline': ['C:\\Program Files\\VMware\\VMware Tools\\vmtoolsd.exe', '-n', 'vmusr'], 'exe': u'C:\\Program Files\\VMware\\VMware Tools\\vmtoolsd.exe', 'pid': 120, 'name': u'vmtoolsd.exe'}
{'cmdline': ['C:\\Program Files\\Microsoft Office\\Office15\\lync.exe'], 'exe': u'C:\\Program Files\\Microsoft Office\\Office15\\lync.exe', 'pid': 148, 'name': u'lync.exe'}
{'cmdline': ['\\SystemRoot\\System32\\smss.exe'], 'exe': u'C:\\Windows\\System32\\smss.exe', 'pid': 304, 'name': u'smss.exe'}
{'cmdline': ['C:\\Program Files\\McAfee\\Common Framework\\naPrdMgr.exe', '-Embedding'], 'exe': u'C:\\Program Files\\McAfee\\Common Framework\\naPrdMgr.exe', 'pid': 320, 'name': u'naPrdMgr.exe'}
{'cmdline': ['%SystemRoot%\\system32\\csrss.exe', 'ObjectDirectory=\\Windows', 'SharedSection=1024,12288,512', 'Windows=On', 'SubSystemType=Windows', 'ServerDll=basesrv,1', 'ServerDll=winsrv:UserServerDllInit
me': u'csrss.exe'}
{'cmdline': ['wininit.exe'], 'exe': u'C:\\Windows\\System32\\wininit.exe', 'pid': 444, 'name': u'wininit.exe'}
{'cmdline': ['%SystemRoot%\\system32\\csrss.exe', 'ObjectDirectory=\\Windows', 'SharedSection=1024,12288,512', 'Windows=On', 'SubSystemType=Windows', 'ServerDll=basesrv,1', 'ServerDll=winsrv:UserServerDllInit
me': u'csrss.exe'}
{'cmdline': ['C:\\Program Files\\Microsoft SQL Server\\90\\Shared\\sqlwriter.exe'], 'exe': u'C:\\Program Files\\Microsoft SQL Server\\90\\Shared\\sqlwriter.exe', 'pid': 492, 'name': u'sqlwriter.exe'}
{'cmdline': ['C:\\Windows\\system32\\services.exe'], 'exe': u'C:\\Windows\\System32\\services.exe', 'pid': 500, 'name': u'services.exe'}
{'cmdline': ['C:\\Windows\\system32\\lsass.exe'], 'exe': u'C:\\Windows\\System32\\lsass.exe', 'pid': 516, 'name': u'lsass.exe'}
{'cmdline': ['C:\\Windows\\system32\\lsm.exe'], 'exe': u'C:\\Windows\\System32\\lsm.exe', 'pid': 528, 'name': u'lsm.exe'}
{'cmdline': ['winlogon.exe'], 'exe': u'C:\\Windows\\System32\\winlogon.exe', 'pid': 572, 'name': u'winlogon.exe'}
{'cmdline': ['C:\\Windows\\system32\\svchost.exe', '-k', 'DcomLaunch'], 'exe': u'C:\\Windows\\System32\\svchost.exe', 'pid
{'cmdline': ['C:\\Windows\\system32\\svchost.exe', '-k', 'RPCSS'], 'exe': u'C:\\Windows\\System32\\svchost.exe', 'pid': 7
{'cmdline': ['C:\\Windows\\system32\\svchost.exe', '-k', 'imgsvc'], 'exe': u'C:\\Windows\\System32\\svchost.exe', 'pid': 7
{'cmdline': ['C:\\Windows\\System32\\svchost.exe', '-k', 'LocalServiceNetworkRestricted'], 'exe': u'C:\\Windows\\System32\
{'cmdline': ['C:\\Windows\\System32\\svchost.exe', '-k', 'LocalSystemNetworkRestricted'], 'exe': u'C:\\Windows\\System32\\
{'cmdline': ['C:\\Program Files\\AskPartnerNetwork\\Toolbar\\apnmcp.exe'], 'exe': u'C:\\Program Files\\AskPartnerNetwork\\
{'cmdline': ['C:\\Windows\\system32\\svchost.exe', '-k', 'LocalService'], 'exe': u'C:\\Windows\\System32\\svchost.exe', '
{'cmdline': ['C:\\Windows\\system32\\svchost.exe', '-k', 'netsvcs'], 'exe': u'C:\\Windows\\System32\\svchost.exe', 'pid':
{'cmdline': ['/load'], 'exe': u'C:\\Program Files\\McAfee\\Common Framework\\McTray.exe', 'pid': 1020, 'name': u'McTray.ex
{'cmdline': ['C:\\Program Files\\McAfee\\Common Framework\\UdaterUI.exe', '/StartedFromRunKey'], 'exe': u'C:\\Program File
{'cmdline': ['C:\\Program Files\\VMware\\VMware Tools\\vmtoolsd.exe'], 'exe': u'C:\\Program Files\\VMware\\VMware Tools\\v
{'cmdline': ['C:\\Program Files\\Microsoft Office\\Office15\\ONENOTEM.EXE', 'sr'], 'exe': u'C:\\Program Files\\Microsoft O
{'cmdline': ['C:\\Windows\\system32\\cmd.exe'], 'exe': u'C:\\Windows\\System32\\cmd.exe', 'pid': 1324, 'name': u'cmd.exe'}
```

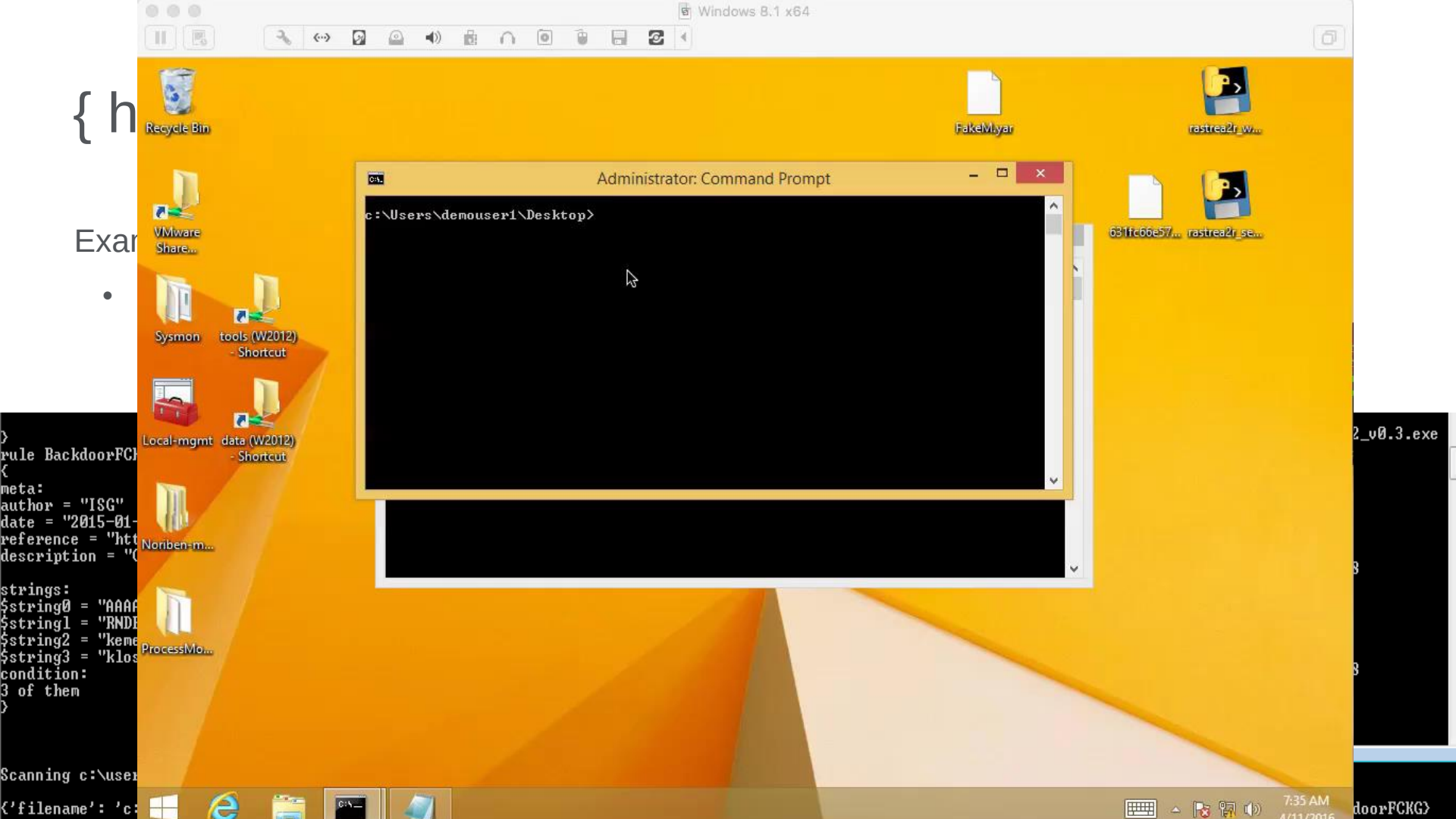
Administrator: Administrator Command Prompt - rastrea2r...

```
C:\Users\user\Desktop\rastrea2r server\binaries>rastrea2r_server_win32_v0.3.exe
Bottle v0.12.8 server starting up (using WSGIRefServer())...
Listening on http://0.0.0.0:8080/
Hit Ctrl-C to quit.


Pulling ransomware.yar

127.0.0.1 - - [09/Oct/2015 21:25:37] "POST /getrule HTTP/1.1" 200 2588
```

# { h

Exar

- 


Windows 8.1 x64
Recycle Bin
FakeM.yar
rastrea2r_w...
VMware Share...
631fc66e57...
rastrea2r_se...
Sysmon
tools (W2012) - Shortcut
Local-mgmt
data (W2012) - Shortcut
Noriben-m...
ProcessMo...
Administrator: Command Prompt
c:\Users\demouser1\Desktop>
7:35 AM
}
rule BackdoorFCK
{
meta:
author = "ISG"
date = "2015-01-
reference = "htt
description = "
strings:
$string0 = "AAAA
$string1 = "RNDI
$string2 = "keme
$string3 = "klos
condition:
3 of them
}
Scanning c:\user
{'filename': 'c:
2_v0.3.exe
doorFCKG}

# { rastrea2r in action };

## Let’s revisit our event…

- Traffic blocked to a suspicious IP
  - What process is generating this traffic on the endpoint? And why?
  - Is there any other malicious activity on this host that is not being detected?
  - How do I respond to this? What should I do next?

| | | | | | | | | |
|---|---|---|---|---|---|---|---|---|
| 7 Oct 2015 11:07:35 EDT | Outgoing Traffic to CIF Malware Domain or IP | 172.17. | | n-p05.corp | | | /Failure | 86.121.110.81 |
| 7 Oct 2015 11:02:34 EDT | Outgoing Traffic to CIF Malware Domain or IP | 172.17. | | n-p05.corp | | | /Failure | 86.121.110.81 |
| 7 Oct 2015 10:57:33 EDT | Outgoing Traffic to CIF Malware Domain or IP | 172.17. | | n-p05.corp | | | /Failure | 86.121.110.81 |
| 7 Oct 2015 10:52:32 EDT | Outgoing Traffic to CIF Malware Domain or IP | 172.17. | | n-p05.corp | | | /Failure | 86.121.110.81 |

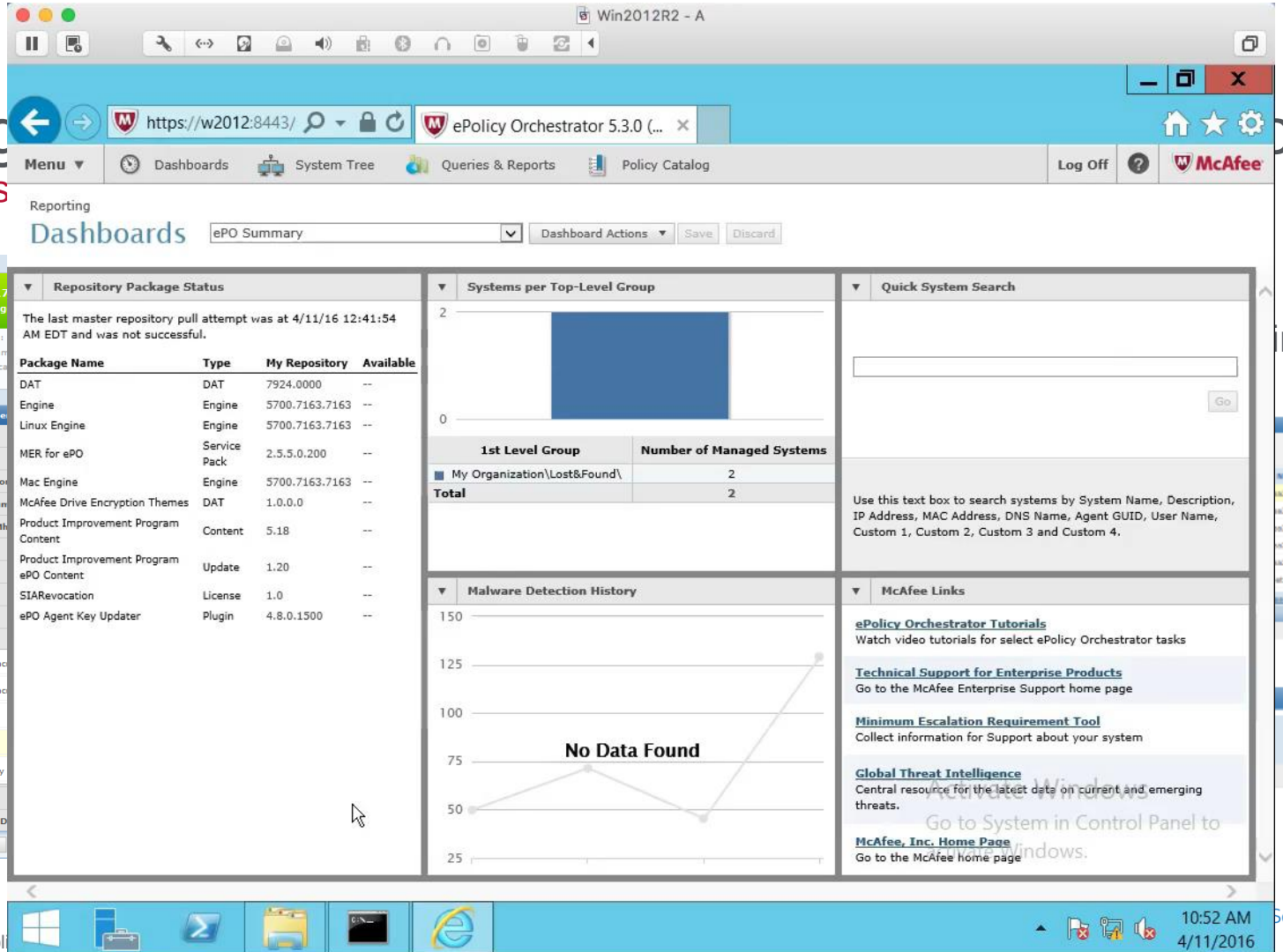
Threat feeds loaded into SIEM (collective intelligence framework)

Source IP/host name

Suspicious domain

# { triag ... ble };

Client tas ... ination



# { analyzing the results (~5 minutes) };

## A folder is created per system, then per collection set (timestamp)

| Name | Date modified | Type |
|---|---|---|
| triage-BHB-NS17N-P05 | 10/7/2015 5:18 PM | File folder |
| memdump-BHB-NS17N-P05 | [illegible] | File folder |
| triage-BHB-IS5W9LA-P01 | [illegible] | File folder |
| triage-BHB-IS5S5-P04 | [illegible] | File folder |
| triage-DC-KRAUS-LPT | [illegible] | File folder |
| triage-CDC-1032-P01 | 10/5/2015 2:02 PM | File folder |
| triage-FMN-6FL-P20 | 10/2/2015 3:11 PM | File folder |
| memdump-FMN-6FL-P20 | 10/2/2015 2:34 PM | File folder |
| triage-BHB-IS5W35-P01 | 10/2/2015 11:51 AM | File folder |
| memdump-BHB-IS5W35-P01 | 10/2/2015 11:36 AM | File folder |
| triage-MMB-15A6P156D1 | 10/2/2015 9:30 AM | File folder |
| memdump-MMB-15A6P156D1 | 10/2/2015 9:21 AM | File folder |
| triage-CMB-4W11-P03 | 9/30/2015 1:36 PM | File folder |
| triage-ENY-2205-P03 | 9/30/2015 12:58 PM | File folder |
| triage-KBR-6W-NS-P00 | 9/30/2015 10:28 AM | File folder |
| triage-9B-NS_13D1 | 9/30/2015 10:20 AM | File folder |
| triage-EMB-07XXBFD-P02 | 9/30/2015 10:05 AM | File folder |
| triage-QPB-05XXXNS-P08 | 9/30/2015 9:40 AM | File folder |
| triage-KBS-CS15-P07 | 9/29/2015 11:18 AM | File folder |
| memdump-KBS-CS15-P07 | 9/29/2015 11:12 AM | File folder |
| triage-55W-EOC-P12 | 9/29/2015 8:51 AM | File folder |
| triage-QMB-01XEX32-P01 | 9/28/2015 3:19 PM | File folder |
| triage-BEB-RD140ED-P01 | 9/25/2015 12:20 PM | File folder |
| memdump-BEB-RD140ED-P01 | 9/25/2015 11:52 AM | File folder |
| triage-BHB-PL4E17E-P02 | 9/25/2015 11:48 AM | File folder |
| triage-KBT-M208-P01 | 9/25/2015 11:46 AM | File folder |
| memdump-KBT-M208-P01 | 9/25/2015 11:38 AM | File folder |

Type: File folder
Date modified: 10/7/2015 5:18 PM
Size: 10.3 MB
Folders: 20151007160754, 20151007211831, mvsbsihj
Files: mvsbsihj.zip, network.pcap, network.pcap.gz

| Name | Date modified |
|---|---|
| 20151006203053 | 10/6/2015 4:45 PM |

# { analyzing the results };

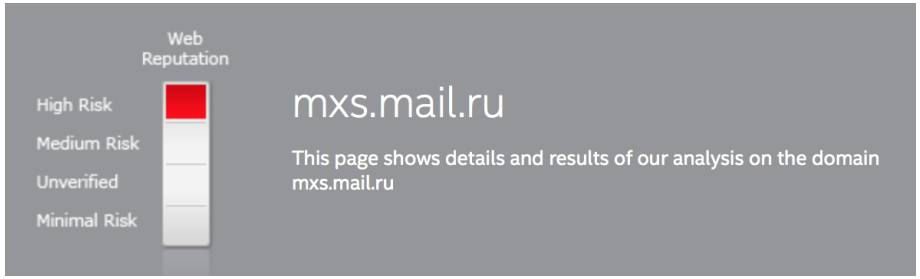
| | | | |
|---|---|---|---|
| 20151006204120-BHB-IS5W9LA-P01-firewall.log | 10/6/2015 4:41 PM | Text Document | 4 KB |
| 20151006204121-BHB-IS5W9LA-P01-hosts.log | 10/6/2015 4:41 PM | Text Document | 1 KB |
| 20151006204121-BHB-IS5W9LA-P01-sessions.log | 10/6/2015 4:41 PM | Text Document | 6 KB |
| 20151006204133-BHB-IS5W9LA-P01-nbtstat.log | 10/6/2015 4:41 PM | Text Document | 1 KB |
| 20151006204133-BHB-IS5W9LA-P01-netstat.log | 10/6/2015 4:41 PM | Text Document | 11 KB |
| 20151006204134-BHB-IS5W9LA-P01-process-list.log | 10/6/2015 4:41 PM | Text Document | 214 KB |
| 20151006204134-BHB-IS5W9LA-P01-services.log | 10/6/2015 4:41 PM | Text Document | 44 KB |
| 20151006204135-BHB-IS5W9LA-P01-tasklist.log | 10/6/2015 4:42 PM | Text Document | 179 KB |
| 20151006204205-BHB-IS5W9LA-P01-at-schtasks.log | 10/6/2015 4:42 PM | Text Document | 16 KB |
| 20151006204208-BHB-IS5W9LA-P01-startup-list.log | 10/6/2015 4:42 PM | Text Document | 8 KB |
| 20151006204214-BHB-IS5W9LA-P01-psinfo.log | 10/6/2015 4:42 PM | Text Document | 1 KB |
| 20151006204214-BHB-IS5W9LA-P01-zRemote.log | 10/6/2015 4:42 PM | Text Document | 1 KB |
| 20151006204216-BHB-IS5W9LA-P01-diskext.log | 10/6/2015 4:42 PM | Text Document | 1 KB |
| 20151006204216-BHB-IS5W9LA-P01-logonsessions.log | 10/6/2015 4:42 PM | Text Document | 6 KB |

# { that sounds highly suspicious… };

```
Caption=ConnectionCenter
Command="C:\Users\BHB-NS17N-P05\AppData\Local\Citrix\ICA Client\concentr.exe" /startup
Description=ConnectionCenter
Location=HKU\S-1-5-21-2250110424-2442967196-2465209428-110119\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
SettingID=
User=CORP\BHB-NS17N-P05


Caption=MSConfig
Command="C:\Users\BHB-NS17N-P05\mvsbsihj.exe"
Description=MSConfig
Location=HKU\S-1-5-21-2250110424-2442967196-2465209428-110119\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
SettingID=
User=CORP\BHB-NS17N-P05


Caption=RTHDVCPL
Command=C:\Program Files\Realtek\Audio\HDA\RtHDVCpl.exe -s
Description=RTHDVCPL
Location=HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
SettingID=
User=Public


Caption=IMSS
Command="C:\Program Files\Intel\Intel(R) Management Engine Components\IMSS\PIconStartup.exe"
Description=IMSS
Location=HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
SettingID=
User=Public
```

# { someone wants to send mail to Russia! }

```
mail.ru
----------------------------------------
Record Name . . . . . : mail.ru
Record Type . . . . . : 15
Time To Live  . . . . : 4
Data Length . . . . . : 8
Section . . . . . . . : Answer
MX Record . . . . . . : mxs.mail.ru
                        10
                        0


Record Name . . . . . : mxs.mail.ru
Record Type . . . . . : 1
Time To Live  . . . . : 4
Data Length . . . . . : 4
Section . . . . . . . : Additional
A (Host) Record . . . : 217.69.139.150


Record Name . . . . . : mxs.mail.ru
Record Type . . . . . : 1
Time To Live  . . . . : 4
Data Length . . . . . : 4
Section . . . . . . . : Additional
A (Host) Record . . . : 94.100.180.150


b-0.19-43000408.9851081.1644.1f0a.2f4a.410.0.9ape7qnbhhzejna5sl525sn3wb.avts.mcafee.com
----------------------------------------
Record Name . . . . . : b-0.19-43000408.9851081.1644.1f0a.2f4a.410.0.9ape7qnbhhzejna5sl525sn3wb.avts.mcafee.com
Record Type . . . . . : 1
Time To Live  . . . . : 3061
Data Length . . . . . : 4
Section . . . . . . . : Answer
A (Host) Record . . . : 127.129.0.128
```



# { what about that funky binary? };

## Always check hashes. Bad guys use Virustotal too!

*Mvsbsihj.exe*

- Low AV detection at the time of submission (checked with PEStudio)
- Injects itself into svchost.exe
- Checks network status
- Downloads a second payload with spambot capabilities
- In addition to sending spam it can download additional plugin components from C&C servers:
  - DDoS attacks
  - Sniff traffic and steal credentials
  - Read messages on Twitter, Skype, Facebook, etc.
  - Bitcoin mining, etc.

| Type | Size | Blacklisted (5) | Value |
|---|---|---|---|
| ascii | 14 | x | VirtualAllocEx |
| ascii | 18 | x | CreateRemoteThread |
| ascii | 11 | x | SendMessage |
| ascii | 8 | x | VBA6.DLL |
| ascii | 15 | x | DllFunctionCall |
| ascii | 40 | - | !This program cannot be run in DOS mode. |
| ascii | 5 | - | .text |
| ascii | 6 | - | `.data |
| ascii | 5 | - | .rsrc |
| ascii | 12 | - | MSVBVM60.DLL |
| ascii | 5 | - | '2@x; |
| ascii | 24 | - | = Filmwissenschaften |

# { what next? };

## Hunting with YARA and rastrea2r

1. Create a new YARA rule based on this sample
2. Scan the environment and triage infected systems
3. Tune the YARA rule based on findings
4. Repeat, rinse and stop once the FULL scope is determined
5. Contain & eradicate
6. Conduct memory analysis and full disk forensics to determine root cause

```
rule systemXYZ-spambot
{
strings:
    $string0 = "fffff."
    $string1 = "AVVWSH"
    $string2 = "AWAVAUATVWSH"
    $string3 = "ffffff."
    $string4 = ".reloc"
condition:
    4 of them }
```

# { the results };

## Where are we now?

- Ability to triage and collect evidence from thousands of endpoints centrally managed by McAfee ePO ***in minutes***
- Triage and evidence collection is **automated**, with **proactive** hunting of IOCs based on FBI TLPs, vendor reports, internal IR investigations and other threat intelligence feeds
- Results of the triage process can be **validated** by trained analysts
- Working on automating evidence/artifacts processing and analysis
- Initial vector of compromise can be determined on most cases

# Thank You!

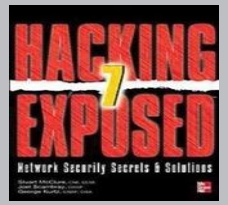
**@aboutsecurity**

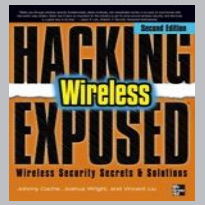
http://blog.ismaelvalenzuela.com

ismael.valenzuela@intel.com

# Thought Leadership

Contributing authors to all editions of Hacking Exposed




**Professors and Lecturers**

**Competition Judges/Mentors**

Foundstone®

intel® Security